PicoBoot-WiFi: implementation plan

Status	Approved v1.5, 2026-11-11; draft v1.6 (phase 5) for approval at the end of phase 5
Design	architecture.md, Approved v1.6
Owner	Remko Kleinjan

Status

Version	Date	What changed and why
v0.1 draft	2026-11-08	First draft. It splits the design's phases (D28) into steps, assigns models and lists what's needed from the owner. The owner's equipment (a current meter, no oscilloscope or logic analyzer) and console (DOL-001 only) don't fit the design's scope-based measurements. Design points DP1–DP5 propose the changes.
v1.0	2026-11-08	The owner approved the draft with DP1–DP5 (”approved, go ahead with phase 0”). DP1–DP5 are now design decisions D31–D35 (design v1.1). Phase 0 starts.
v1.1	2026-11-08	Approved by the owner. Phase 0 as built (see its ”As built” note), and what its results change. **Phase 1:** a new step 1.3 for the glitch protection (D36), the last flash sector kept free (D37), the RP2350 stepping in the report, and a glitch check among the console tests. **Phase 2:** notes on lwIP (DHCP, send buffer) and the Tx power default. **Phase 5:** the 5 V recommendation (D38) in the README. Phase 1's steps are renumbered 1.1–1.12.
v1.2	2026-11-08	Approved by the owner at the end of phase 1. Phase 1: the boot log (D39) and the page's test switches, added before step 1.10 so its 60+ console boots can be read in one go. The phase 1 code review's findings, their fixes, and the re-test before the merge (bench and 10 cold boots, the owner's choice).
v1.3	2026-11-09	Approved by the owner at the end of phase 2. Phase 2 as built (see its ”As built” note), with the owner's choices made during the phase (design D40, D41, and changes to D20 and D26), and what it means for phases 3 and 4.
v1.4	2026-11-10	Approved by the owner at the end of phase 3. Phase 3 as built (see its ”As built” note), with the owner's choices made during the phase (design D11, D12, D14), the phase 2 review's items for phase 3, and the test builds of step 3.7.
v1.5	2026-11-11	Approved by the owner at the end of phase 4. Phase 4 as built (see its ”As built” note), with the owner's choices made during the phase (design D42, D43), its code review, and the `.bss` budget for phase 5.
v1.6 draft	2026-11-11	Phase 5: the security review of step 5.1, its fixes and their re-test in the console. For approval at the end of phase 5.

How this plan works

- **Steps:** every phase is split into steps. Each step has a ”done when” check.
- **Gates:** a phase starts only after the previous one is merged. Phase 0 can still change the design. If it does, the design gets a new version (v1.1, …) before phase 1 starts.
- **Branches:** one per phase: `phase-0-checks`, `phase-1-core`, `phase-2-wifi`, `phase-3-firmware-ota`, `phase-4-payload-ota`, `phase-5-release`. `main` holds only reviewed work.
- **Commits:** once this plan is approved, each step is committed on its phase branch without asking each time.
- **The end of a phase:**
  1. the owner's hardware tests;
  2. a code review on the branch (fixes go on the same branch);
  3. the design and this plan updated to match what was built;
  4. the owner's review;
  5. a merge into `main` with a merge commit, and the status lines saying ”merged”;
  6. the PDF exports regenerated (`docs/export-pdf.sh`).

Who does what

Who	Does
Opus 5.5 (this session)	The plan, the core in C (loader, records, injection, measurement, Wi-Fi blob hook, flash writer, OTA and trial logic, payload slots, httpd integration), CMake and CI, local builds, and reviews of all subagent work
Sonnet 5.5 subagents, each in its own git worktree	Independent parts with a written contract from Opus: the web UI, the JavaScript `.dol` converter, the Python tools (update-file builder, CLI client)
Fresh Opus 5.5 reviewer	The end-of-phase code review of the code this session wrote itself, so the review isn't anchored on the author's reading
Fable 5.1	The security review in phase 5. It wrote none of the code
Owner	Hardware tests on the DOL-001, pushes to GitHub (CI runs on push), reviews and approvals, merges

What's needed from the owner

What	When
A Pico 2 W for the console, ideally a second one for bench tests	Phase 0
The DOL-001 with the SD2SP2 and the HDMI adapter fitted, wired as today (3V3 feed)	Phase 0
A current meter or shunt in the Pico's 3.3 V feed	Phase 0
A phone (and ideally a second one with the other OS, for the captive-portal check) and a laptop	Phase 0, 2
A GitHub repository `r3mko/PicoBoot-WiFi` with Actions enabled; pushing each phase branch	Phase 1
Payload files to test with: Swiss r2119 and gekkoboot r9.4 (UF2 and `.dol`)	Phase 0, 4

No servers, DNS, accounts or tokens are needed.

Design points for approval

The owner's answers on 2026-11-08 (equipment, console, readout) don't fit three design decisions. The owner approved these points with the plan, and they are now design decisions D31–D35 (design v1.1).

DP1 → D31: the Pico measures its own boot timing (changes D10).

- **How:** a third, passive PIO state machine watches CS. It doesn't touch the two injection programs.
  - It sets a PIO IRQ flag on the first CS falling edge, and the CPU, which is idle during the injection, timestamps that flag.
  - It counts every CS pulse until the injection ends.
  - The DMA transfer count gives the number of 1 KB transfers delivered.
- **The margin:** time of the first CS minus time of ”PIO ready”.
  - A positive margin together with a successful boot proves the PIO was in time.
  - A short CS count shows missed pulses.
- **Why:** no oscilloscope or logic analyzer is available.
- **Reuse:** the same counters become the boot diagnostics of D22.
- **What it can't do:** it can't see the supply ramp before the RP2350 leaves reset. That doesn't matter, because the margin is measured from the Pico's own start.

DP2 → D32: a minimal Wi-Fi readout comes early (changes D28).

- **Phase 0:** the measurement build is PicoBoot-DX v0.10 plus the DP1 counters. After the injection it starts an access point with a plain-text report page. It also serves two load-test URLs, a large download (Tx load) and an upload sink (Rx load).

- **Phase 1:** brings the Wi-Fi blob hook (D14) and the same minimal page forward from phase 2. The blob doesn't fit inside a 256K slot, and the results have to come out of a closed console.

DP3 → D33: the rail check without a scope (changes D28 phase 0).

- **Average current:** measured with the meter in four states:
  - AP off;
  - AP idle;
  - a client connected;
  - the download running.
- **Rail sag:** a functional stress test replaces the scope. The large download runs at full Tx power while Swiss loads a game from the SD2SP2, with the HDMI adapter on. What to watch for:
  - console glitches;
  - video artefacts;
  - a Pico brown-out (`HAD_B0R`, counted in the report);
  - Wi-Fi drops.

DP4 → D34: the DOL-001 is the test console.

- All hardware tests run on the owner's DOL-001 with the SD2SP2 and the HDMI adapter.
- The README says the DOL-101 is expected to work (same IPL path as PicoBoot) but is untested.

DP5 → D35: no pre-releases; the first GitHub release is 1.0.0 (changes D24).

- **Test builds:** come from CI artifacts on the pushed phase branch, or from Opus's local Docker build, which uses the same SDK and toolchain as CI.
- **Versions:** builds carry 0.N.0-dev (N = the phase) plus the git hash.

Repository layout

```
CMakeLists.txt              loader + firmware targets, install UF2, update file
pico_sdk_2_import.cmake
src/common/                 layout.h (the flash map, D6), records, boot info, version
src/loader/                 the loader (D7)
src/firmware/               injection, measurement, Wi-Fi, web, OTA
src/firmware/pio/           PIO programs (injection from PicoBoot-DX, CS counter)
linker/                     linker overrides (loader 16K, firmware 256K slot)
web/                        static UI sources (gzipped into the firmware)
tools/                      Python: process_ipl, uf2 packer, update builder, CLI
tests/                      Python tests, PIO simulator, host C tests, layout check
hwtest/dx-measure/          phase 0 measurement build (PicoBoot-DX + DP1 + DP2)
docker/Dockerfile         local build image: SDK 2.3.1, picotool 2.3.1, arm-none-eabi-gcc
docs/                       design, plan, research, API, update-file format
```

`src/common/layout.h` is the only place the flash map is written down. The linker scripts, the tools and the layout check read it.

Phase 0: hardware checks

Branch: `phase-0-checks`, **merged** into `main` on 2026-11-08. **Goal:** measure what the design couldn't know, before any core code exists.

#	Step	Who	Done when
0.1	**Measurement build** `hwtest/dx-measure`. Start from PicoBoot-DX v0.10 (pico2_w) and add: the DP1 counter state machine; after the injection, the pico-examples access point (WPA2, test password) with `/report` (text), `/stream` (large download) and `/sink` (upload). The report shows the margin, the CS count, transfers delivered, injection complete or stalled, reset reason (`HAD_POR`/`HAD_BOR`), time to Wi-Fi up and uptime.	Opus	Builds in Docker; the PIO simulator shows the injection unchanged with the counter running
0.2	**Bench check**: Pico 2 W on USB, no console	Owner	The AP is visible; `/report` says "no CS seen"; `/stream` downloads
0.3	**Cold boots in the console**, 3V3 wiring as today: 10× gekkoboot r9.4, 10× Swiss r2119, reading `/report` after each	Owner	20 results recorded; the radio works on the console's 3.3 V; every boot good
0.4	**Warm board**: 5 boots after 30 minutes of play	Owner	Recorded, compared with 0.3
0.5	**Current**: AP off (during the injection), AP idle, client connected, `/stream` running (DP3)	Owner	Four values recorded
0.6	**Range**: phone RSSI at 1, 3 and 5 m with the console closed, in two board positions	Owner	Recorded
0.7	**Stress test** (DP3): `/stream` while Swiss loads a game from the SD2SP2, HDMI adapter on	Owner	Glitches, video, brown-outs and Wi-Fi drops recorded
0.8	**Results** in `docs/research/phase0-results.md`, design changes (if any) as a new design version	Opus	The owner approves the results and any design change

As built (2026-11-08):

- **Moved forward from phase 1** (needed for the measurement build): `docker/Dockerfile`, `tools/process_ipl.py`, gekkoboot r9.4 in `assets/ipl/`, and `tests/pio_sim.py`.
- **Added to the measurement build** while testing:
  - D8's warm-reboot rule, with *Reboot* buttons to test it;
  - test switches: built-in IPL, Wi-Fi 60 s late, CS pull-up;
  - a check of the last flash page for the E10 block;
  - a second, clock-qualified CS counter;
  - the pin levels at "PIO ready".
- **Step 0.3b added:** the glitch series after boot 12 of step 0.3 (parts 1–3).
- **Step 0.5:** measured the 3V3 voltage instead of the current, because the owner's setup can't put a meter in series.
- **Bug found on the bench and fixed:** lwIP drops DHCP requests when `LWIP_DHCP` is off, even for a DHCP *server*.

Code review of phase 0 (a fresh Opus 5.5 reviewer, 2026-11-08):

- **Overall:** no serious bugs. The injection programs are byte-identical to PicoBoot-DX v0.10, the build is clean under `-Wall -Wextra`, the tests pass, and the warm-reboot and flash-write constraints hold.
- **The measurement build stays as it was measured.** Its findings are requirements for the phase 1 code that reuses it:

#	Finding	Where it's handled
1	The clock-qualified count must check that CS is still low when CLK rises (`jmp pin`); otherwise a glitch plus a CLK pulse while CS is high still counts. Already corrected in the PicoBoot-DX handoff	1.3, 1.4: in the injection and the counters, with simulator cases for CLK while CS is high (`pio_sim` gets `JMP !X` and `JMP PIN`)

#	Finding	Where it's handled
2	Recovery from a torn record write erased the newer records in the same sector	1.5: erase only at a sector start; host test
3	The phase 0 power-on rule also injects on BOR and RUN; D8 is HAD_POR only. Keep POWMAN `scratch[0]` for the marker	1.6
4	A failed `tcp_write` with nothing in flight is never retried	2.2: retry from the poll callback (or lwIP httpd handles it)
5	A client FIN cuts the response short	2.2: finish the response, then close
6	The `tcp_abort` fallback after `tcp_close` would be unsafe inside a callback	2.2: no such fallback, or return `ERR_ABRT`
7	Raw and clocked counts are read at different moments, so a false GLITCH is possible	1.4: snapshot while CS is high, or re-read until stable
8	`dma_channel_abort()` without first clearing the channel's EN bit (RP2350-E5)	1.7
9	The counters use PIO IRQ flags 0 and 1, which are only safe outside the injection's PIO block	1.4: use flags the injection doesn't use, or keep them in another block
—	Test gaps: the counter's X set-up and read path, and coupling between the counters and the injection, aren't exercised	1.4

Phase 1: core

Added during the phase (2026-11-08), for step 1.10:

- **The boot log (D39):** the last 32 boot reports on the page.
- **Page buttons:**
  - the payload for the next power-ons (payload 1, payload 2, built-in);
  - the CS test mode (PicoBoot's pull-down, for the glitch check), stored as a test flag in boot control.

Branch: `phase-1-core`, **merged** into `main` on 2026-11-08. **Done when (D28):**

- the console boots a payload through the loader on a cold and on a warm board;
- a warm reboot doesn't inject;
- the boot-time budget is met (D10);
- the clock is set (D27).

#	Step	Who	Done when
1.1	**Skeleton**: CMake with the loader and firmware targets, `layout.h` (last flash sector kept free, D37), linker overrides (loader ≤16K, firmware ≤256K), CI (ubuntu-26.04: build, tests, layout check) with the phase 0 `docker/Dockerfile` setup, LICENSE (GPL-2.0-only, D29), README stub	Opus	CI builds both ELFs; the layout check passes
1.2	**Injection port** from PicoBoot-DX: PIO programs, `pio.c`, payload check (base address as a parameter), `ipl.h` from `tools/process_ipl.py` (both from phase 0), and the remaining PicoBoot-DX tests next to `tests/pio_sim.py`	Opus	CI tests green, PIO simulator included

#	Step	Who	Done when
1.3	**Glitch protection** (D36): • CS pull-up before the PIO starts; • a clock-qualified count of the 224 skipped pulses in `on_transfer`, CLK rising while CS is still low (`jmp pin`), as in the PicoBoot-DX handoff (`docs/handoff/`). Simulator tests: with a CS glitch without clocks before the IPL read, PicoBoot-DX's programs shift the payload (phase 0's test) and the new ones don't; without a glitch, the output is bit-identical; every address clock of the first payload transfer is seen	Opus	Simulator tests green, including the phase 0 glitch case
1.4	**CS counters and boot report** (D31): the raw and clocked counters from phase 0 as firmware code, plus the RP2350 stepping (for RP2350-E9)	Opus	The simulator test counts the right pulses and transfers
1.5	**Records** for boot control and settings (D23): two sectors, sequence number, CRC32, newest valid record wins	Opus	Host C tests pass, including a torn write that falls back to the previous record
1.6	**Loader** (D7, D8): • power-on rule (`HAD_P0R` + POWMAN scratch marker); • slot choice as one pure function; • boot info in POWMAN scratch; • `rom_chain_image()`; • the other slot if one is empty, BOOTSEL if both are; • no clock setup (`pico_minimize_runtime`)	Opus	Host tests cover the decision table; the size check is ≤16K
1.7	**Firmware start-up**: read boot info; power-on → inject payload 1, 2 or built-in (payload read through the untranslated XIP window); warm → no injection	Opus	On the bench, the loader chains into slot A and `/report` shows a warm boot
1.8	**Wi-Fi blob hook** (D14, DP2): the blob is loaded from Wi-Fi A/B at its fixed address. The minimal AP and `/report` page from 0.1 run inside the slot, with a *reboot* button for the warm-reboot test	Opus	The AP comes up from a slot build with the blob outside the image
1.9	**Install UF2**: `tools/mkuf2.py` packs absolute regions (rp2350-arm-s): loader, blank boot control and settings, Wi-Fi A (Wi-Fi-only blob, built from the SDK header) and slot A, without picotool's E10 block (D37). CI artifact `picoboot-wifi-install.uf2`	Opus	Python tests for the packer; the UF2 parser shows the right ranges and nothing at or above `0x3FF000`; a bench install over PicoBoot-DX keeps payload 1
1.10	**Console tests**: • 10 cold boots each with gekkoboot and Swiss; • warm board; • *reboot* from the page while a game runs (the console keeps running and the report says ”warm, no injection”); • the glitch check: 40 cold boots with a test switch that restores PicoBoot's CS pull-down, where every boot must start and any glitch must show as survived in the report. Compare the margin with phase 0	Owner	Results recorded; the margin difference gives the loader's cost; no blue screens

#	Step	Who	Done when
1.11	**Budget and clock**: set the D10 budget and the D27 clock and flash divider from phase 0 and 1.10. If the loader is too slow, the R1 fallback (loader starts the PIO)	Opus + owner	Values written into the design; budget met
1.12	**End of phase**: fresh Opus review, fixes, design and plan updated, merge	Opus, owner	Merged

Code review of phase 1 (a fresh Opus 5.5 reviewer, 2026-11-08):

- **Overall:** no high or medium defects. The loader and D8 rule, the injection port, records and ring log, flash writes and payload bounds held when traced. The build is clean, the tests pass, and the built install UF2 places every part at its `layout.h` offset with nothing at or above `0x3FF000`.
- **Re-test before the merge** (the owner's choice): on the bench, a test UF2 blanks slot A and the board must come up in BOOTSEL (finding 3); after a reinstall, the page; then 10 Swiss cold boots.

#	Finding (all low)	Where it's handled
1	The Wi-Fi blob header check could wrap (`clm_offset + clm_len`), so a bad header could send the CYW43 driver past the area	Fixed in phase 1; host test. Checking the blob's SHA-256 after the injection: phase 3 (D14)
2	`ringlog_read()` rechecked every entry's CRC for each entry returned, about 1,000 CRCs over uncached flash per page load	Fixed: one pass
3	With both slots empty, the loader's reboot into BOOTSEL waits on the watchdog tick, which only the SDK's clock setup (skipped) starts	Fixed: the loader starts the tick. Bench test before the merge
4	The DNS server could reply with bytes past the query; the DHCP option search could return an option past its buffer (both from pico-examples)	Fixed. The phase 5 security review looks at both again
5	The D36 check is ”CLK reads high”, not ”CLK rises”: a false CS pulse while CLK already reads high still counts	**Not changed** (the owner's choice): a known limit in D36, not seen on hardware
6	The CS pull-down test flag lives in boot control: one POST turns the D36 pull-up off for every later power-on	2.4: the release web UI has no test switches; the firmware ignores the flag outside test builds; bit 7 stays reserved
7	250 MHz was a constant, and after the injection the clock dropped to half of it (125 MHz)	Fixed: `PICOBOOT_WIFI_INJECTION_KHZ` and `PICOBOOT_WIFI_FLASH_CLKDIV` are build settings (D27); after the injection the clock returns to the SDK's 150 MHz, as on warm boots
8	The ring log holds 17 to 32 entries, not ”the last 32”	D39 says ”up to 32”
9	A button's failed boot control write still looked successful	Fixed: the page says so
10	CI uploaded the stand-alone `firmware.uf2`, which writes over the loader, boot control and Wi-Fi A	Fixed: only the install UF2 and the ELFs
—	Test gaps: `payload_check()`, the Wi-Fi blob check, the built install UF2 against the built parts	Added. Not added: a power cut during a ring-log erase, sequence wrap-around in the log, a shared boot-info encoder (later phases)
—	From the boot 95 page: the log's margin column showed the false CS edge on glitch boots	Fixed: it shows the margin to the first real transfer

Phase 2: Wi-Fi

Branch: `phase-2-wifi`, **merged** into `main` on 2026-11-09. **Done when (D28):** a phone reaches the status page from a closed console.

#	Step	Who	Done when
2.1	**Settings** on the records from 1.4: SSID, password, channel, country, Tx power, auto-off, LED; defaults from D30	Opus	Host tests; settings survive a reboot
2.2	**Network**: AP with WPA2-AES (D30), DHCP, DNS answering every name with `192.168.4.1`, redirects for the phone probe URLs, lwIP httpd with custom files. From phase 0: keep `LWIP_DHCP` on (without it lwIP drops DHCP requests), and size the TCP send buffer for throughput (8 × MSS gave 0.4–0.95 MB/s)	Opus	iOS and Android open the page by themselves on the bench
2.3	**API contract** `docs/api.md` (status, settings, diagnostics) and the JSON handlers	Opus	Handlers answer as specified
2.4	**Web UI**: plain HTML/CSS/JS, status, diagnostics and settings pages, default-password banner (D19), gzip build step	Sonnet (worktree)	Works against the API on the bench; under about 30 KB gzipped; Opus reviewed
2.5	**Diagnostics** (D22): the boot report from 1.3, plus the loader decision, the payload choice and why, time to Wi-Fi up	Opus	Shown on the status page
2.6	**Auto-off** (D20), **Tx power** (the `qtxpower` iovar), **LED** patterns (D26). The default Tx power is set lower than the maximum, since phase 0 found plenty of range (−42 dBm at 5 m)	Opus	Auto-off after 10 minutes without a client; Tx power changes the RSSI
2.7	**Console tests**: captive portal on both phones, settings, banner, auto-off, Tx power against range and current; injection results the same as in phase 1	Owner	Recorded
2.8	**End of phase**: fresh Opus review, fixes, docs, merge	Opus, owner	Merged

As built (2026-11-09): results in phase2-results.md; test builds are `0.2.0-dev`.

Step	What was built	The owner's choices
2.1	Settings as a record (D40), with value checks; a stored value that isn't allowed falls back on its own default	Default channel 6; Tx power in named levels
2.2	lwIP httpd in place of the raw TCP server. Every answer is a custom file with its own headers: 302 to the start page for unknown paths (the captive portal), 204 for `/favicon.ico`. httpd copies answers into its segments, so one freed at close can't be read again by a retransmission. The firmware got 25 KB smaller (the old server's `sscanf`)	
2.3	`docs/api.md`; a small JSON writer and flat-object reader; the handlers; POST bodies only as `application/json` (a CSRF guard). An access-point restart restarts the DHCP server too, because the network interface comes back with another number	D41: Wi-Fi changes restart only the access point, at once, and stay on trial until a client comes back through it; the password is write-only

Step	What was built	The owner's choices
2.4	The web UI as one page with tabs (6.4 KB gzipped) and `tools/mkfsdata.py`, built by a Sonnet subagent in a worktree and reviewed. The phase 1 test page moved to `/test`, in test builds only; release builds also ignore the CS test flag (phase 1 finding 6)	One page with tabs; light or dark as the phone; the test page kept at `/test`
2.5	The boot report records boot control's payload choice, so the diagnostics say when the built-in payload went instead. The boot log format changed (version 2)	
2.6	Auto-off powers the CYW43 down (`cyw43_arch_deinit()`), then the firmware sleeps between interrupts. Tx power through the `qtxpower` iovar, from the main loop. The LED patterns of D26	Tx power 5, 10 and 15 dBm and the chip's limit; after a stall the LED blinks for as long as Wi-Fi is on. Auto-off runs up to 1.5 minutes late (the chip's client timeout): accepted
2.7	Console tests all passed	5 Swiss boots instead of 10 accepted

For later phases:

- **Phase 3:**
  - uploads need a streaming POST path: net.c now collects bodies of up to 1 KB;
  - `LWIP_HTTPD_POST_MANUAL_WND` holds the upload back while a sector is erased (D18);
  - httpd also calls `httpd_post_finished()` when a connection closes mid-body, so the writer must tell a complete upload from a cut one;
  - D41's trial (in `settings.c`) is a small model of D12's trial and keep.
- **Phase 3 and 4:** uploads use `application/octet-stream` (D18), which, like JSON, needs a CORS pre-flight from another site, so the CSRF guard carries over. New UI parts go into `src/web/index.html` as tabs.
- **Phase 4:** the payload choice moves from the test page into the UI.

Code review of phase 2 (a fresh Opus 5.5 reviewer, 2026-11-09):

- **Overall:** no high defects. The httpd answer lifetimes, the POST paths (split bodies, refusals, connections closing mid-body), the access-point restart and the D41 sequences held when traced against the lwIP and CYW43 sources. The JSON reader took about 5 million fuzzed inputs under ASan and UBSan without a memory error or an accepted body that the settings checks would refuse. A release-version build has no test page.
- **Re-test before the merge** (the owner's choice): a short bench test. Both phones open the UI; a POST with a wrong Host gets 403; a country change restarts the access point and phones rejoin; the test page's buttons still work.

#	Finding	Where it's handled
1	**Medium:** DNS rebinding got past the CSRF guard. The Pico's DNS answers every name with its own address, so a page opened elsewhere could point its own name at the Pico and send same-origin POSTs without a preflight. It could change settings, reboot, or set a known password	Fixed: POSTs must say `Host: 192.168.4.1` (403 otherwise), for the API and the test page; `docs/api.md` says so. Phase 4's backups, which include the settings, are to be POST-only for the same reason
2	If the chip didn't take the access point down, the restart kept the old settings (the driver skips the set-up while the BSS is up), and an old client could confirm a change that never ran	Fixed: the restart checks the BSS and retries; if it stays up, the change can't be confirmed and is undone at the next start
3	Undoing an unconfirmed change brought back every setting saved with it, not only the Wi-Fi ones	Fixed (the owner's choice): only the SSID, password, channel and country go back, as D41 says; host test

#	Finding	Where it's handled
4	Test builds: the test page printed the SSID unescaped, and its POSTs had no guard	Fixed: escaped, and the Host check covers them
5	A `.DS_Store` or editor backup in `src/web/` stopped the build	Fixed: skipped; test
6	The UI said ”nothing was saved” when a save's answer was lost, though a Wi-Fi change may have gone through	Fixed: it says the outcome is unknown, waits for the Pico and shows its settings
7	Out of memory, httpd had no error answer of its own: the client got a 302 to the start page, which the UI could take for success	Fixed: a fixed 503 answer
8	The diagnostics answer (about 18 KB at most today) had little room in its 20 KB buffer for later fields	Fixed: 32 KB
—	**For phase 3:** • once a watchdog runs (3.4), the idle loop after auto-off must stop it or feed it, or auto-off becomes a reboot loop; • records filter by format version, so an older firmware in the other slot could erase a newer record; the record writer must never erase the newest record of any version before slots can switch; • `wifi.c`'s restart, confirm and auto-off logic has no host tests; D12's trial should be pure C, as D41's is	Phase 3 steps 3.3 and 3.4

Phase 3: firmware OTA

Branch: `phase-3-firmware-ota`, **merged** into `main` on 2026-11-10. **Done when (D28):** an update, a failed trial and a switch all work in the console without USB.

#	Step	Who	Done when
3.1	**Update-file format** `docs/update-format.md` (D11): header, slot image, optional blob, SHA-256s	Opus	Format reviewed by the owner
3.2	**Update-file builder** `tools/mkupdate.py`, with tests and a CI artifact	Sonnet (worktree)	Tests green; the output matches the format; Opus reviewed
3.3	**Flash writer**: streaming POST with a manual TCP window, sector erase and program through `flash_safe_execute()`, SHA-256 on the fly (`pico_sha256`) and after reading back, Wi-Fi blob pairing (D14), boot control ”pending”	Opus	Bench: an update lands in slot B and verifies; a corrupted file is refused
3.4	**Trial, keep and fallback** (D12, D13): • kept after a good power-on injection plus Wi-Fi, or on *Keep*; • ”trial failed”; • crash-loop counter; • watchdog and HardFault → reboot; • loader decision tests extended	Opus	Host tests; on the bench a crash build falls back
3.5	**Firmware page**: upload with progress, both slots, *Keep*, *Boot slot X*	Sonnet (worktree)	Works on the bench; Opus reviewed
3.6	**CLI** `tools/picoboot-wifi.py status / update` (standard library only)	Sonnet (worktree)	Updates a bench board; Opus reviewed

#	Step	Who	Done when
3.7	**Test builds**: a firmware that crashes at start-up and one that crashes after 5 s, as CI artifacts	Opus	Built
3.8	**Console tests**: • update A→B, kept after a power-on; • crash build → fallback; • switching slots; • power cut during an upload → the old firmware boots; • update with a different blob (the Bluetooth variant as a stand-in)	Owner	Recorded
3.9	**End of phase**: fresh Opus review, fixes, docs, merge	Opus, owner	Merged

As built (2026-11-09): results in phase3-results.md; test builds are `0.3.0-dev`.

Step	What was built	The owner's choices
3.1	`docs/update-format.md`: a 256-byte header with the layout and loader versions, then the image and the blob	The blob always in release files; downgrades allowed, with a warning
3.2	`tools/mkupdate.py` (Sonnet, reviewed), `build/picoboot-wifi-update.bin` on every build, a CI artifact	
3.3	`update.c` (pure, host tested: whole uploads into a simulated flash) and `updater.c`; uploads stream from httpd's POST callbacks straight to flash, so no manual TCP window was needed. A host test feeds the files `mkupdate.py` makes through `update.c`. An upload takes about 4 s	
3.4	Loader version 2: the session in POWMAN scratch, a crash being any reset without the firmware's clean-reboot word. The firmware's side in `slots.c` (pure). A watchdog (8 s) and a fault handler. No updates while on trial. Records leave another version's record alone (phase 2 review)	3 crashes for the crash loop; the fallback for good
3.5, 3.6	`POST /api/boot` (keep, boot a slot) and each slot's version from its binary info; the Firmware tab (the UI is 9.5 KB gzipped) and `tools/picoboot-wifi.py`, each by a Sonnet subagent in a worktree, reviewed	
3.7	`PICOBOOT_WIFI_TEST_CRASH=startup` / `after5s` and `PICOBOOT_WIFI_BLOB=marked`, as CI artifacts	
3.8	Console tests all passed after one fix: a failed trial's note in the session word also blocked a new trial of that slot in the same session; the firmware now clears it when it sets up a new trial. The SDK's Bluetooth blob, the planned stand-in for a new blob, didn't come up without Bluetooth support (its trial failed and was undone); the stand-in became the Wi-Fi blob with a marker	

Code review of phase 3 (a fresh Opus 5.5 reviewer, 2026-11-10):

- **Overall:** the normal paths the bench and console tests covered held up. The findings were in paths those tests didn't reach: a firmware running in place of the active one, a switch to a slot that only counted as installed, the keep rule, and a cut-off upload. Findings 1–4 were confirmed by host simulations.
- **Re-test before the merge:** bench (the access point reported up, keep, a cut-off upload followed by another, the Firmware tab after a USB install) and one console power-on for the keep.

#	Finding	Where it's handled
1	**High:** an update could go into the active slot, after a fallback boot or in the half second before a switch's reboot. It then started without a trial or a way back. And a cut-off upload over an old image could leave a slot the boot ROM accepts (the image has no hash)	Fixed: updates only from the active firmware (`slots_update_target()`); a firmware started in place of the active slot takes over; no upload while a reboot is due, and no other POST while an upload runs; the loader never starts an empty slot; the image's first sector is written last. Host tests
2	**Medium-high:** a trial was kept even if Wi-Fi never came up: the driver doesn't report a failed start	Fixed (the owner's choice): kept only if the chip reports the AP up; on trial without Wi-Fi, a reboot as a crash
3	**Medium:** ”Boot slot X” to a slot that only counted as installed (after a USB install it may hold anything) made it active at once	Fixed: it goes on trial; after a USB install slot B counts as empty; only a slot with a PicoBoot-WiFi firmware is offered
4	**Medium:** a cut-off upload left the SHA-256 hardware claimed; the next upload waited for it until the watchdog reset, counted as a crash	Fixed: an unfinished hash is released first
5	**Low:** the UI and CLI reported ”on trial” after an upload without checking that the new firmware came up	Fixed: both compare the running slot with the one installed; CLI test
6	**Low, for phase 4:** once a record's version changes, a firmware of the other version rewrites its own record in place, without the power-cut safety	Phase 4: allow for it when a record's version changes

For phase 4:

- **Boot control** keeps its format: a new `BOOTCTL_VERSION` needs a loader that reads it, so a loader version 3 and a USB install.
- **The payload and ”original IPL once” choices** go into `POST /api/boot` beside `keep` and `slot`.
- **Backups** that include the settings (the Wi-Fi password) are to be POST-only (phase 2 review, DNS rebinding).
- **The update writer's pattern** (pure C behind an io struct, host-tested with simulated flash and interop with the Python tools) suits the payload upload of step 4.1.

Phase 4: payload OTA

Branch: `phase-4-payload-ota`. **Done when (D28):** Swiss and gekkoboot uploaded and chosen over Wi-Fi.

#	Step	Who	Done when
4.1	**Payload upload** (D15, D16): streaming UF2 parser (any family, blocks from `0x10080000`), raw payload, checks, write to the slot that isn't booting, metadata (name, size, SHA-256, fingerprint) in boot control	Opus	Host tests for the parser with the real Swiss and gekkoboot UF2s; bench upload
4.2	**USB rule** (D17): fingerprint check before the injection, record after it	Opus	A USB install over a payload-2 choice boots payload 1
4.3	**”Original IPL once”**: a one-shot flag in boot control, cleared at the next power-on	Opus	Bench and host tests
4.4	**Backups**: streaming downloads of payload 1/2, the firmware slot and settings	Opus	Downloaded SHA-256 matches the status page

#	Step	Who	Done when
4.5	**`.dol` converter** in JavaScript (port of `process_ipl.py` and the UF2 payload format), with a Node test in CI against the Python output	Sonnet (worktree)	Byte-identical to Python for gekkoboot r9.4 and Swiss r2119; Opus reviewed
4.6	**Payload page**: upload `.dol`/`.uf2`/`.bin`, choose, delete, download	Sonnet (worktree)	Works on the bench; Opus reviewed
4.7	**CLI** payload commands: upload, choose, convert	Sonnet (worktree)	Works on the bench; Opus reviewed
4.8	**Console tests**: • Swiss and gekkoboot as UF2 and as `.dol`; • choosing each; • the USB rule; • ”original IPL once”; • power cut during a payload upload; • backup	Owner	Recorded
4.9	**End of phase**: fresh Opus review, fixes, docs, merge	Opus, owner	Merged

As built (2026-11-11): results in phase4-results.md; test builds are `0.4.0-dev`.

Step	What was built	The owner's choices
4.1	Boot control format 2 (the names) and loader version 3, one USB install; records of any format, written to alternate sectors (phase 3 review, finding 6). `payloadup.c` (pure, host tested with the real Swiss and gekkoboot UF2s) and `payloads.c`: `POST /api/payload`, choose, rename, delete, the status. `sha.c` shares the SHA-256 hardware	D42: names you choose; uploads into payload 2 while the built-in boots; the chosen payload can't be deleted
4.2	The USB rule: a fingerprint of payload 1, recorded after a complete injection, so the console's power-on shows the switch; a choice, rename or upload over Wi-Fi settles it. Pure functions in `payload.c`, host tested	
4.3	Original IPL once: no injection, then Wi-Fi 1.5 s later	
4.4	`GET /api/backup/…`: a payload as it sits in flash, the running firmware as an update file (its header made on the Pico, byte-identical to `mkupdate.py`'s), the settings without the password; streamed through httpd's dynamic read, one transfer at a time	D42: plain downloads; payloads raw; only the running firmware
4.5	`src/web/dol.js` (Sonnet, reviewed): byte-identical to `process_ipl.py`, by a Node test that includes a round trip through the release payloads	
4.6	The Payloads tab, and the backup and restore links (Sonnet, reviewed); the UI is 12.6 KB gzipped	
4.7	The CLI's payload, IPL-once, backup and restore commands (Sonnet, reviewed), with its own copy of the converter, pinned to `process_ipl.py` by a test	

Step	What was built	The owner's choices
4.8	Console tests all passed, with two fixes. The USB rule had recorded the install at the drag-and-drop's reboot on USB power, so the console's power-on didn't show it. The margin had fallen to 156.5 ms: `.bss`, zeroed on the boot ROM's clock before the injection, had grown to 77 KB. With the upload writers and lwIP's pools in `.uninitialized_data` (20 KB) it's 163.9 ms, 1.6 ms below PicoBoot-DX, and the layout check keeps `.bss` under 24 KB	D43: a loader stub for ordinary `.dol` files, later

Code review of phase 4 (a fresh Opus 5.5 reviewer, 2026-11-11):

- **Overall:** no high findings; one medium and ten low, mostly power-cut timing and wrong states that the console tests didn't reach. All fixed in `721d396`.
- **Re-test before the merge:** bench and console, in phase4-results.md.

#	Finding	Where it's handled
1	**Medium:** an update to a phase 3 firmware was accepted. It reads only boot control format 1, so it ran on the defaults: payload 1 whatever the choice, and its trial never kept	Fixed: an update file whose loader requirement is below 3 is refused (`needs_usb_install`). Host test
2	**Low:** a power cut in the erase of a delete, or of an upload into payload 1, could leave the old header, which the USB rule took for a new payload	Fixed: the first page is zeroed before boot control records the change
3	**Low:** the fingerprint was in effect the size: builds of a payload share their first 256 bytes	Fixed: also 64 words spread over the payload and its last 256 bytes. Host test
4	**Low:** the CLI took a lost answer for a success when the target held the same payload already	Fixed: the target must be the choice too. CLI test
5	**Low:** an over-long `X-Name` was dropped instead of refused	Fixed: 400 `bad_value`
6	**Low:** the test page didn't escape the payload names	Fixed
7	**Low:** wrong states: a USB-install notice after a firmware USB install, ”now the choice” after another choice, the notice on an IPL-once boot, a payload named for a skipped boot, downloads during an upload	Fixed
8	**Low:** `docs/api.md` out of step in places	Fixed
9	**Low:** on an IPL-once boot, Wi-Fi started during the console's own IPL read (D9)	Fixed: Wi-Fi waits 1.5 s
10	**Low:** lwIP's pools in uninitialised memory rely on lwIP setting what it reads	`MEMP_MEM_INIT`: lwIP zeroes them in `lwip_init()`, after the injection
11	**Low:** the USB rule had no host tests	Fixed: two pure functions, host tests of its sequences

For phase 5:

- **`.bss`** costs about 0.13 ms of the margin per KB; the layout check fails it over 24 KB in the firmware.

Phase 5: release 1.0

Branch: `phase-5-release`. **Done when (D28):** the owner's hardware test passes on a fresh install and on an upgrade from PicoBoot-DX.

#	Step	Who	Done when
5.1	**Security review** of the whole network side: httpd handlers, upload parsers, flash-writer bounds, settings input, DNS and DHCP	Fable 5.1	Findings reported; fixes on the branch, reviewed by Opus
5.2	**README** (install, upgrade from PicoBoot-DX, wiring with the 5 V recommendation of D38, default password, recovery, DOL-101 note), `docs/api.md` final	Opus	Owner reviewed
5.3	**Release workflow**: on a tag, build and attach the install UF2, the update file and checksums	Opus	A test tag on a fork produces the assets
5.4	**Acceptance** on the DOL-001: fresh install, upgrade from PicoBoot-DX, OTA from a 0.4.0-dev build to 1.0.0	Owner	Passed
5.5	**Merge and tag 1.0.0**	Owner	Released

Security review (step 5.1, Fable 5.2, 2026-11-11):

- **Overall:** no critical, high or medium findings; seven low and five informational. The upload parsers, the flash writers, the header and JSON parsers, the records and the DNS and DHCP servers were fuzzed on the host (about 20 million inputs, with AddressSanitizer and UndefinedBehaviorSanitizer). The fixes are in `360d8dd`.
- **Re-test:** in the console, build `0.5.0-dev+3806ed3`: passed, in phase5-results.md.

#	Finding	Where it's handled
L1	A page a client opened elsewhere can read the GET answers through DNS rebinding (httpd gives the GET path no headers for a Host check)	Accepted by the owner: no GET answer holds a secret; documented in `docs/api.md`, D19 and the README
L2	A failed `malloc` panicked (the SDK's default), a crash D12 counts; the 503 paths never ran	`PICO_MALLOC_PANIC=0`
L3	The DHCP option search could read past the message	A minimum length per option, and the search stays within the bytes received
L4	Eight made-up MAC addresses held all DHCP leases for a day	10-minute leases; an expired one is taken over by a request too
L5	Restoring a crafted settings file could set a password the owner doesn't know	The page and the CLI refuse a file that sets a password
L6	The CLI saved a backup under any name the device sent (a dotfile, a script)	Only a plain name with the expected extension, else the default. CLI test
L7	The page could be framed by another site, for a tricked click	`X-Frame-Options: DENY`, `frame-ancestors 'none'`
I1	What D11 implies: anyone with the password can install any firmware, which could also write the OTP	Documented in D19 and the README
I2	Repeated stores could wear the record sectors	A store that changes nothing writes nothing; the rest is accepted (it needs the password)
I3	A cut-off blob could leave a Wi-Fi area that looks whole	The Wi-Fi area's first sector, then the image's, programmed last of all. Host test
I4	The POST answer files (`/.api`, …) answered a plain GET	Served only right after a POST
I5	The DHCP lease expiry shifted a 16-bit value as `int`	A 32-bit cast

Local builds and CI

- **Local:** Opus builds in Docker (`docker/Dockerfile`: Ubuntu, SDK 2.3.1, picotool 2.3.1, arm-none-eabi-gcc), the same setup the size research used (sizes.md). Test UF2s go to the owner from there or from CI.
- **CI:** builds, then runs every test:
  - Python tools;

- the PIO simulator;
- host C tests;
- the layout check;
- the Node test for the JS converter (from phase 4).

The CI run is the authority on whether a step is done.